

Rapporto sulla Sicurezza Informatica: Il Social Engineering

1. Introduzione e Definizione

Il **Social Engineering** (Ingegneria Sociale) è una tecnica di manipolazione psicologica utilizzata dai criminali informatici per indurre le persone a compiere azioni specifiche o a divulgare informazioni riservate.

A differenza degli attacchi informatici tradizionali, che sfruttano vulnerabilità software o hardware, il Social Engineering prende di mira l'**essere umano**. Si basa sull'assunto che sia molto più facile ingannare una persona per ottenere una password piuttosto che tentare di violare un sistema crittografato attraverso la forza bruta.

In ambito cybersecurity, viene spesso definito come "l'hacking delle persone".

2. Leve Psicologiche: Su cosa fanno leva gli attaccanti

Gli ingegneri sociali sono abili manipolatori che sfruttano i **bias cognitivi** (errori di giudizio sistematici) e le emozioni umane. Le leve principali includono:

- **Urgenza e Paura:** Creare una situazione di emergenza (es. "Il tuo conto verrà bloccato tra 10 minuti") per indurre la vittima ad agire istintivamente, bypassando il pensiero critico.
- **Autorità:** Fingersi dirigenti, forze dell'ordine o tecnici IT. Le persone tendono ad obbedire alle figure autoritarie senza mettere in discussione la richiesta.
- **Fiducia e Disponibilità:** Sfruttare la naturale inclinazione umana ad aiutare il prossimo o a fidarsi di chi appare gentile e collaborativo.
- **Curiosità:** Utilizzare esche interessanti (es. "Stipendi dirigenti 2024.pdf" o una chiavetta USB abbandonata) per spingere la vittima a cliccare o inserire un dispositivo.
- **Reciprocità:** L'attaccante offre qualcosa (un aiuto, un piccolo favore, un'informazione) per creare un senso di debito nella vittima, che si sentirà obbligata a ricambiare (spesso fornendo dati sensibili).

3. Metodi e Vettori di Attacco

Le tecniche utilizzate sono in continua evoluzione, ma le categorie principali rimangono costanti:

A. Phishing e varianti

- **Phishing:** Invio massivo di email fraudolente che sembrano provenire da fonti legittime (banche, corrieri, provider di servizi) per rubare credenziali.

- **Spear Phishing:** Una versione altamente mirata del phishing. L'attaccante utilizza tecniche di OSINT (Open Source Intelligence) per studiare la vittima specifica (tramite social media, LinkedIn) e creare messaggi personalizzati estremamente credibili.
- **Whaling:** Phishing mirato ai "pesci grossi" (C-level executives, amministratori delegati) per autorizzare bonifici fraudolenti o ottenere accessi privilegiati.

B. Vishing (Voice Phishing)

L'uso del telefono per ingannare la vittima. Oltre al camuffamento del numero (spoofing), gli attaccanti utilizzano oggi l'Intelligenza Artificiale per clonare la voce di dirigenti o persone fidate (Deepfake Audio), rendendo le truffe estremamente convincenti.

C. Smishing (SMS Phishing)

L'uso di SMS o messaggi su app di messaggistica (WhatsApp, Telegram) contenenti link malevoli. Sono molto efficaci perché le persone tendono a fidarsi dei messaggi sul cellulare più che delle email.

D. Pretexting (Creazione del pretesto)

L'attaccante crea uno scenario inventato (un pretesto) per ottenere informazioni.

- *Esempio:* Un attaccante chiama fingendosi un dipendente dell'HR e dice: "Stiamo aggiornando i dati dei dipendenti, mi confermi la tua data di nascita e codice fiscale?".

E. Baiting (L'esca)

Offrire qualcosa che la vittima desidera.

- *Fisico:* Lasciare una chiavetta USB infetta con etichetta "Bonus Aziendali" in un parcheggio o in sala mensa.
- *Digitale:* Offrire il download gratuito di un software costoso o di un film, che in realtà contiene malware.

F. Tailgating / Piggybacking

L'accesso fisico non autorizzato. L'attaccante segue una persona autorizzata attraverso una porta sicura (es. sfruttando la cortesia di chi "regge la porta") per entrare in aree riservate senza badge.

G. Watering Hole

Un vettore di attacco che colpisce gruppi specifici di utenti infettando i siti web che questi visitano abitualmente (es. portali di settore o siti di fornitori).

4. Strategie di Difesa e Mitigazione

Poiché l'attacco mira alla mente umana, la tecnologia da sola non è sufficiente. La difesa deve

essere stratificata.

1. Formazione e Consapevolezza (Security Awareness)

È la difesa più efficace. I dipendenti devono essere addestrati a:

- Riconoscere i segnali di allarme (urgenza immotivata, errori grammaticali, mittenti sospetti), anche attraverso simulazioni periodiche di phishing che testano la reattività in un ambiente sicuro.
- Non condividere mai password o codici OTP, nemmeno con il supporto IT.
- Verificare l'identità del richiedente tramite un canale alternativo (es. se ricevi un'email dal CEO che chiede un bonifico, chiamalo al telefono per conferma).

2. Procedure di Verifica (2FA)

Istituire processi rigidi per le operazioni sensibili.

- Nessun bonifico o scambio IBAN può essere autorizzato solo via email. È necessaria una seconda conferma (telefonica o vocale).

3. Controlli Tecnici

- **MFA (Multi-Factor Authentication):** L'autenticazione a più fattori è fondamentale. Anche se un attaccante ruba la password tramite phishing, non potrà accedere senza il secondo fattore (token, app, impronta).
- **Filtri Email avanzati:** Per bloccare spam e tentativi di spoofing.
- **Endpoint Protection:** Antivirus e EDR per bloccare l'esecuzione di malware se un utente clicca erroneamente su un link.

4. Sicurezza Fisica

- Policy rigide sull'uso dei badge.
- Divieto di far entrare sconosciuti (anti-tailgating).
- Clean Desk Policy (non lasciare password scritte su post-it o documenti sensibili sulle scrivanie).

5. Conclusione

Il Social Engineering dimostra che la sicurezza informatica non è solo un problema tecnologico, ma anche umano. Un firewall da milioni di euro può essere reso inutile da una semplice telefonata persuasiva. La cultura del sospetto costruttivo ("zero trust") è l'unica vera barriera contro queste minacce.